ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

AutomationDirect DirectSOFT (DirectLOGIC programming software) · Component type: **Software Application (SAR) - PLC engineering software** · Target SL = SL 3

Where to work	**DirectSOFT** on a Windows host: it connects to DirectLOGIC PLCs over the serial **K-sequence** port or an **ECOM** Ethernet module; it sets/uses the PLC **multilevel password** (Program › Password); the **project files** live on the host. DirectSOFT has no login/RBAC of its own - auth is delegated to the PLC + host OS. Installer from AutomationDirect.
Ports / paths	DirectSOFT is a client: it connects out to PLCs over serial K-sequence or Ethernet (Modbus/ECOM, e.g. **TCP 502**). Project files live on the host - protect them. Runs on Windows; harden the host and patch DirectSOFT / the .NET runtime it uses.
Notes	SAR - AutomationDirect DirectSOFT (DirectLOGIC programming software). **Thin tool:** the security that matters is (a) the PLC program password it sets (assess on the DL06 sheet), (b) the host OS controlling who may run DirectSOFT, and (c) protecting the DirectSOFT project files. It has no user accounts / RBAC / TLS of its own. Confirm the DirectSOFT version and patch level.
How to read	Each row = native step-by-step (DirectSOFT / host) + command-level external-tool steps, noting where control is **delegated to the PLC or host**. Default read-only. Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the DirectSOFT project (.prj) with element documentation, the PLC program export, and the comm / security settings.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	DirectSOFT has **no app-level login**; authentication is enforced (a) at the **host OS** - only authorized Windows users may run DirectSOFT - and (b) at the **PLC** - the multilevel program password must be supplied to read/write the program. Verify both; record the DirectSOFT-level absence as a residual. **Test:** from DirectSOFT, attempt to read/write a password-protected PLC without the password -> denied. **Ext. tools:** Host (who may run DirectSOFT); DirectSOFT (PLC password prompt on protected access).	Host restricts who runs DirectSOFT; PLC password gates program access; DirectSOFT residual documented.	Partial/Compensating.
SR/CR 1.2	Software process / device identification	Confirm each PLC is uniquely identified in the DirectSOFT link setup (COM/node or ECOM Module ID/IP) and DirectSOFT connects only to the intended device. **Ext. tools:** DirectSOFT (Link setup); `nmap --script modbus-discover -p 502 <plc>` (ECOM).	Unique PLC link identity; no rogue devices.	
SR/CR 1.3	Account management	DirectSOFT has no user database - manage the **host OS accounts** that may run it (least privilege) and the **PLC program password** as a controlled secret; no shared passwords. **Ext. tools:** Host account review; PLC password-custody record.	Host + PLC-password controlled/least-privilege; DirectSOFT has none by design.	Compensating.
SR/CR 1.4	Identifier management	Confirm unique host user IDs and a unique PLC link identity (node / ECOM ID+IP); no reuse. **Ext. tools:** Host/AD; DirectSOFT link setup; inventory.	Unique host-user and PLC identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.5	Authenticator management	The authenticator is the PLC password (set via DirectSOFT - limited legacy strength) and the host/AD password policy. Set a non-default PLC password, store it in the vault, and rely on strong host/AD credentials. **Ext. tools:** DirectSOFT (PLC password set); host/AD policy.	PLC password set (non-default, weak-strength residual noted); strong host policy.	Partial (legacy).
SR 1.6	Wireless access management	**N/A.** Software with no wireless interface. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A.** DirectSOFT and the DirectLOGIC link have no PKI/TLS. Record N/A; confidentiality/integrity via segmentation + host disk encryption for stored projects. **Ext. tools:** Confirm no TLS on the link (Wireshark = cleartext).	N/A device/tool PKI; compensating segmentation/host encryption.	N/A.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm DirectSOFT masks the PLC password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticator obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The PLC has no lockout and DirectSOFT has no login; rely on host/AD lockout for the DirectSOFT workstation + segmentation + monitoring. **Ext. tools:** Host/AD lockout; note PLC/tool residual.	Host/AD lockout; PLC/tool residual recorded + compensating controls.	Partial/Compensating.
SR/CR 1.12	System use notification	No DirectSOFT banner; enforce the approved use notice on the host (GPO). **Ext. tools:** Host `gpresult /h gp.html`.	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the DirectSOFT host + PLCs are in the trusted cell/OT zone; remote engineering via VPN/jump host; Modbus/ECOM not exposed to untrusted networks. **Ext. tools:** `nmap -Pn -p 502,80 <plc>` from the untrusted side (expect filtered); firewall review.	Engineering access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Authorization is enforced at the PLC (program password + mode switch) and the host (only authorized users run DirectSOFT). DirectSOFT has no role model. A protected program cannot be read/changed without the password. **Test:** attempt a program read/write on a password-protected PLC without the password -> denied. **Ext. tools:** DirectSOFT (password behavior); host app-execution control.	PLC password + host control gate changes; no tool RBAC (residual noted).	Partial/Delegated.
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the DirectSOFT laptop and removable media (OS device-control) and the serial/USB-serial adapter; only authorized projects/firmware loaded. **Ext. tools:** Host removable-media policy; project/firmware provenance.	Portable/engineering media controlled.	
SR/SAR 2.4	Mobile code	No general-purpose mobile code; confirm only the signed DirectSOFT runs and no untrusted add-ons execute. **Ext. tools:** Installed-component review; verify installer signature.	Only signed/required components; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; the PLC re-challenges for the password after reconnect. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; PLC re-challenges.	Compensating.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.6	Remote session termination	Confirm DirectSOFT connections can be closed; serial is single-master and the ECOM bounds concurrent connections so conflicting programming is prevented. **Ext. tools:** DirectSOFT connection review; ECOM connection limits.	Sessions terminable; concurrency bounded.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	DirectSOFT/PLC have no native audit and no per-user identity. Capture program changes via DirectSOFT project version control on the host, and log PLC/comms events at the SCADA + a network IDS; forward to the SIEM. Attribution is at the host/tool layer. **Ext. tools:** DirectSOFT project version control; SCADA/IDS/SIEM.	Changes tracked at the host; PLC events off-device; no per-user attribution (residual).	No native audit - Compensating.
SR/CR 2.9	Audit storage capacity	All logging is off-device - confirm the SCADA/IDS/SIEM are sized/retained and alert on collection failure. **Ext. tools:** SIEM/IDS retention + source-silent alert.	Off-device logs sized/retained; audit-failure alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the host clock is synced (NTP) so DirectSOFT project/change timestamps correlate with SCADA/SIEM. **Ext. tools:** `w32tm /query /status`.	Accurate host timestamps; correlated with SCADA/SIEM.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	DirectSOFT-to-PLC comms (K-sequence / Modbus) are **unauthenticated cleartext** with no TLS - contain them: serial point-to-point / physically controlled, Modbus TCP in a segmented zone. No cleartext across a zone boundary. **Ext. tools:** Wireshark `modbus` (cleartext, in-zone only); firewall review.	Programming comms contained/segmented; no crossing the boundary.	No crypto - Compensating.
SR/SAR 3.2	Protection from malicious code (component)	Confirm DirectSOFT software integrity: install only the AutomationDirect-**signed** DirectSOFT (verify the installer signature / download from AutomationDirect); host anti-malware; restrict install to admins. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV; installed-version review.	Signed software validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify (via DirectSOFT) that the PLC password, PLC services (ECOM web), and the host controls match the baseline; confirm DirectSOFT itself is patched. **Ext. tools:** DirectSOFT (PLC settings vs baseline); host review; version check.	PLC + host security match the baseline after change; DirectSOFT patched.	
SR/CR 3.4	Software & information integrity	Protect the DirectSOFT **project files**: host ACLs, encrypt at rest (BitLocker), and version under change control; use DirectSOFT compare to detect program drift vs the PLC. **Ext. tools:** Host ACL on project folder; `certutil -hashfile proj.prj SHA256`; DirectSOFT online-vs-offline compare.	Project files protected + versioned; program drift detected.	
SR/CR 3.5	Input validation	Patch known DirectSOFT CVEs and confirm DirectSOFT handles malformed PLC responses without crashing. **ISOLATED:** test against a bench PLC. **Ext. tools:** Nessus/OpenVAS on the host; AutomationDirect/CISA advisory cross-check; ISOLATED malformed-response test.	Known CVEs patched; malformed input handled safely.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.7	Error handling	Confirm DirectSOFT handles errors gracefully without leaking sensitive info (no plaintext PLC password in logs). **Ext. tools:** DirectSOFT / host event-log review.	Graceful error handling; no secret leak.	
SR/CR 3.8	Session integrity	**N/A / limited.** No secured session (cleartext K-seq/Modbus, no TLS); integrity via containment + serial point-to-point. Record N/A + compensating segmentation. **Ext. tools:** Wireshark (confirm in-zone containment).	N/A/limited; compensating segmentation recorded.	N/A/Partial.
SR/CR 3.9	Protection of audit information	Protect the host/SCADA/SIEM stores and the DirectSOFT project records; restrict who can access them (host ACLs). **Ext. tools:** Host ACL; SIEM/SCADA access review.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the host, remove DirectSOFT project files, exported programs, the stored PLC password, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** grep projects/exports for secrets; confirm removed; BitLocker status.	Projects/secrets purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	DirectSOFT has no native crypto; confidentiality relies on host disk encryption + segmentation. Protect stored projects/passwords at rest. **Ext. tools:** Confirm host disk encryption; no plaintext PLC password stored.	Host encryption + segmentation; no plaintext secrets stored.	N/A/Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the DirectSOFT host + PLCs sit in a segmented cell/OT zone behind a firewall; only required Modbus/ECOM flows cross; remote engineering via a jump host; no flat convergence with IT. **Ext. tools:** `nmap -p 502,80 <plc>` per zone; firewall rule review.	Host + PLCs in a segmented zone; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Programming software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: keep separate project folders per zone and least-privilege host access; do not co-mingle unrelated criticality. **Ext. tools:** Project/host segregation review.	Projects partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm DirectSOFT project history and host logs are readable/exportable by authorized staff and forwarded to the SIEM; a passive OT IDS (Modbus-aware) on the cell segment gives PLC-comms visibility. **Ext. tools:** DirectSOFT export; host logs; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	DirectSOFT is not a runtime service; confirm the host is resourced/hardened and PLC connections are bounded so a flood cannot deny programming access; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; PLC/ECOM connection-limit review.	Host/connection resources bounded; programming access available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the DirectSOFT project files (+ the PLC program export) are backed up (versioned, offline) and a restore is tested (rebuild the host + re-download to a spare PLC). **Ext. tools:** Backup repository; restore test (host + spare PLC).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: run DirectSOFT on a hardened least-privilege host, install only DirectSOFT, keep it patched, use it to set the PLC password + disable unused PLC services (per the DL06 sheet), and remove sample projects. **Ext. tools:** Host hardening review; DirectSOFT version; PLC service config.	Least functionality on host + PLC; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the DirectSOFT version, the host OS, and the managed PLCs (model/firmware) so vulnerabilities track against AutomationDirect / CISA advisories. **Ext. tools:** DirectSOFT version; host inventory; AutomationDirect/CISA feeds.	Accurate version + managed-PLC inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
DirectSOFT	Native program & PLC-security config (all FRs)	Link setup; Program › Password (set the PLC multilevel password); online-vs-offline compare; project version control. Assess the PLC on the DL06 sheet. Back up the project.	Read/authorized; unlock only for change tests.
Host OS controls	Who may run DirectSOFT + protect projects (1.1, 2.1, 3.4, 4.2)	App-execution control (only authorized users), removable-media policy, ACLs + BitLocker on the project folder.	Windows admin review.

Tool / method	Verifies	How to use — steps / example	Constraints
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from AutomationDirect.	Read-only.
nmap	PLC/service exposure & segmentation (1.13, 5.x)	`nmap -p 502,80 <plc>`; `nmap --script modbus-discover -p 502`; scan per zone.	Read-only; authorized.
Wireshark	Comms integrity (3.1, 3.8)	Filter `modbus`; confirm programming comms are cleartext but contained in-zone.	Passive; SPAN/tap only.
Nessus / OpenVAS + AutomationDirect/CISA advisories	CVE scan (3.5, 7.8)	Scan the DirectSOFT host for known CVEs; cross-check AutomationDirect / CISA advisories.	ISOLATED/representative; authorization.